MERROWFIELD DIGITAL

Playbook: Other malware

Document Playbook 03 | Rev 3 | Effective 9 February 2026 | Owner: Security Operations | Review cycle: 12 months

1. What this playbook covers

This playbook covers malicious code other than ransomware: information stealers, trojans, keyloggers, cryptominers, remote access tools, malicious browser extensions and web shells. It is used by the Security Analyst who investigates, from the first alert until the incident is closed.

2. How it is usually recognised

- an endpoint alert for a known malicious file or behaviour
- a host contacting a known command-and-control address
- a threat intelligence match on a file hash
- a suspicious process started from an office document
- a web shell found on a server during routine scanning

3. The first hour

1. Isolate the host from the network.
2. Block the file hash across the endpoint estate and the command-and-control domain at the proxy, then hunt for the same indicators on other hosts.
3. Reset the credentials of everyone who used the host, including those saved in its browsers.
4. Remove malicious browser extensions by policy.
5. Take a server carrying a web shell out of service and rebuild it from a clean image.

4. Evidence to preserve

- a memory capture or disk image of the host
- the endpoint process tree and the quarantined file
- proxy and DNS logs for the command-and-control address

5. Establishing the facts a report needs

Whatever is decided, the decision needs these facts, established as early as they can be:

- what data was on the host or reachable from it, including saved credentials and local caches
- whether anything was sent out - whether exfiltration is confirmed
- how many hosts carry the same indicators
- whether any customer-facing service was affected

6. Reporting

Which reporting procedures apply is settled from the incident's facts by the rules in Plan 01, section 8, and each procedure's deadlines are read from that procedure. This playbook sets no deadline of its own, and the decision belongs to the Data Protection Officer.

Malware on a machine that held no personal data and touched no service customers use is usually recorded only; the rules in Plan 01 settle it.

7. What affected customers should do

When customers are told, the notice gives them these steps, in this order:

- Usually no action is needed.
- If we tell you your account details may have been exposed, change your password and turn on two-step verification.
- Be careful with unexpected emails about your account, and go to the app or website directly rather than following a link.

8. Closing the incident

Reimage affected hosts, close the route the malware arrived by, and review macro and extension policies.